

Những chỗ lủng trong đặc tả nghiệp vụ sàn rao vật hai trực

Đối chiếu **DAC-TA-NGHIEP-VU-CHUAN.pdf** (bản đích, 05/10/2026) với **LUAT-NGHIEP-VU.pdf** (bản mô tả hệ đang chạy, 02/10/2026) và với mã nguồn backend docs/market.

Ngày rà soát	06/10/2026
Phạm vi	Toàn bộ 19 phần của bản đích, bảng bất biến BT-01 đến BT-30, và danh sách thay đổi ở Phần 18.
Cách đối chiếu	Đọc hai tài liệu trọn vẹn. Mỗi chỗ ghi "code hiện tại" đều đã mở đúng hàm trong docs/market/src để xác nhận, không suy từ tài liệu.
Dành cho	Đội viết đặc tả và đội xây lại, trước khi chốt bản đích.

Kết luận chung. Bản đặc tả viết chặt, có bất biến đánh số và nguyên tắc "mỗi luật phải sai được" là đúng hướng. Còn **23 chỗ lủng**, chia ba nhóm: **A** mâu thuẫn trong chính đặc tả (6), **B** luật chưa được định nghĩa (15), **C** đặc tả đối chiếu so với code đang chạy mà không nêu lý do (2).

Nhóm nguy hiểm nhất là những chỗ **code hiện tại đã làm đúng mà đặc tả bỏ mất** (A5, A6, B1, B3, B8, B9, C1, C2): đội xây lại sẽ tin đặc tả và làm hệ mới kém hơn hệ cũ.

Cao Sai luật hoặc mất hàng rào an toàn, phải sửa trước khi code. **Trung bình**

Hành vi lệch thiết kế hoặc gây việc thừa cho người duyệt. **Thấp**

Lỗi cạnh, mặc định từ chối vẫn an toàn nhưng cần ghi rõ.

A. Mâu thuẫn trong chính đặc tả

A1 Lướt từ chối của máy không thuộc mức độ nào

Cao

§9.1 §9.3 §10.3 BT-07

Vấn đề §9.1 nói tin dính cụm cấm "được tính là vi phạm" để khoá sau 3 lần trong 7 ngày. §9.3 nói "máy từ chối KHÔNG trừ uy tín". §10.3 và BT-07 nói mức độ quyết định MỌI hậu quả, và "vi phạm" thì trừ 1 bậc. Lướt từ chối của máy vì vậy không phải "sai sót" (có án phạt) cũng không phải "vi phạm" (không trừ bậc).

Hệ quả Một mức độ thứ ba tồn tại trong hành vi nhưng không có trong bảng. Ca kiểm thử cho BT-07 không viết được vì không biết kỳ vọng.

Đề xuất Thêm dòng thứ ba vào bảng §10.3, ví dụ "vi phạm do máy": vào án phạt và đếm khoá, không trừ bậc, không xoá chuỗi sạch. Ghi rõ nó có làm đồng hồ 30 ngày ở §11.4 chạy lại hay không.

A2 Ba câu khác nhau về nhóm đích của một request

Cao

§3.3 §8.2 BT-17

Vấn đề	§3.3: nhóm đang làm việc đến từ một header riêng mỗi request. §8.2: yêu cầu tạo tin phải nêu nhóm đích và bậc phủ sóng tường minh. BT-17: mã nhóm do client gửi luôn bị bỏ qua khi quyết định phạm vi. Header cũng là client gửi.
Hệ quả	Đội xây lại không biết đọc nhóm đích từ đâu. Đọc từ header là tái tạo đúng lỗi "không gửi mã nhóm thì rơi vào nhóm đang đứng" mà §8.2 muốn bỏ.
Đề xuất	Một câu duy nhất: header là ngữ cảnh cho thao tác đọc, body là nhóm đích cho thao tác đăng, cả hai luôn đối chiếu với quan hệ thành viên tại thời điểm request. Sửa lời BT-17 thành "mã nhóm trong body hoặc query không bao giờ mở rộng phạm vi".

A3 Đường vào nhóm riêng tư và bốn tổ hợp công tắc chưa có bảng

Trung bình

§4.3 §4.4

Vấn đề	§4.4 vừa nói nhóm riêng tư vào bằng "gửi đơn, quản trị duyệt tay", vừa nói "mã tham gia là đường vào duy nhất của nhóm riêng tư". Hai công tắc Công khai và Nhận đơn tham gia tạo bốn tổ hợp nhưng không tổ hợp nào được định nghĩa hành vi. "Bị từ chối thì chờ 7 ngày, áp cho cả nhóm công khai" vô nghĩa khi nhóm công khai vào ngay, không ai duyệt.
Hệ quả	Không viết được ca kiểm thử cho đường vào nhóm; mỗi người đọc hiểu một kiểu.
Đề xuất	Một bảng 4 dòng: Công khai × Nhận đơn, mỗi dòng ghi ai tìm thấy, ai vào bằng cách nào, có cần duyệt không. Mã tham gia là cách <i>tìm ra</i> nhóm riêng tư, còn vào thì theo công tắc Nhận đơn.

A4 "Vết cấp quyền luôn có hai người" khi chỉ có một người cấp được

Cao

§5.5 BT-28 BT-29

Vấn đề	BT-28 chốt đúng một quản trị hệ thống. §5.5.1 chốt chỉ người đó cấp quyền. Người thứ hai duy nhất có thể xuất hiện trong vết là người nhận, nên luật "hai người" không chặn được gì. Quan trọng hơn: tài khoản đó là điểm chết đơn.
Hệ quả	Mất hoặc bị khoá tài khoản này là không cấp quyền, không sửa danh mục, không ân xá, không gỡ khoá 3 lần cho ai được. Đặc tả không có đường khôi phục.
Đề xuất	Ghi một quy trình khôi phục ngoài runtime (seed lại từ cơ sở dữ liệu, có nhật ký), hoặc cho phép một tài khoản dự phòng ở trạng thái ngủ. Sửa lời §5.5.2 cho khớp thực tế.

A5 Báo cáo về người đi vào hàng đợi không có thẩm quyền

Trung bình

§13.2

Vấn đề	Đặc tả nói báo cáo về người "đóng dấu nhóm của người tố", nhưng cùng mục lại nói thẩm quyền đóng báo cáo phải đối xứng với thẩm quyền xử lý đối tượng. Quản trị nhóm của người tố không có quyền gì trên một người không thuộc nhóm họ.
Code hiện tại	Đã đúng. Chỉ đóng dấu nhóm khi người bị tố cũng đang là thành viên nhóm đó; còn lại về hàng đợi quản trị hệ thống (audit 2.5).
Đề xuất	Chép luật của code vào §13.2 và đổi nhãn mục này từ GIỮ sang đúng nghĩa.

A6 "Sửa rồi đăng lại" không có đường đi trong bảng chuyển trạng thái

Cao

§7.2

§9.3

§10.3

Vấn đề	§10.3 nói từ chối mức sai sót thì "sửa rồi đăng lại được". Bảng §7.2 không có dòng Bị từ chối → Chờ duyệt; lỗi ra duy nhất là Đã xoá. Nếu "đăng lại" nghĩa là tạo tin mới thì tin đó dính ngay cờ "trùng tiêu đề 7 ngày" của §9.3, ăn thêm hạn mức, và tin cũ nằm lại 90 ngày.
Code hiện tại	Đã đúng. Sửa tin bị từ chối mức sai sót đưa tin về Chờ duyệt; mức vi phạm thì không có cửa sửa, phải đăng tin mới (audit 1.20).
Đề xuất	Thêm dòng "Bị từ chối (sai sót) → Chờ duyệt · Chủ tin · Sửa nội dung" vào §7.2, và loại tin đăng lại khỏi phép kiểm trùng tiêu đề.

B. Luật còn thiếu

B1 Không có trần tin đang hiển thị

Cao

§12

§12.2

Vấn đề	Hạn mức chỉ áp cho tin CHỜ, và đếm theo từng danh mục hoặc từng nhóm. Một tài khoản bậc 2 giữ được vô hạn tin đang hiển thị, và 10 tin chờ ở mỗi danh mục nhân với số danh mục.
Code hiện tại	Có trần. Trần tin sống theo bậc uy tín (tin đang hiện cộng tin chờ), kiểm cả khi gia hạn tin hết hạn để không vượt trần bằng cách đăng trước rồi gia hạn dần.
Hệ quả	Xây theo đặc tả là mất hàng rào chống spam duy nhất trên tin đã lên bảng. Đây là lỗi lớn nhất của bản đích.
Đề xuất	Thêm bảng "trần tin đang hiện theo bậc" vào §12, kèm luật gia hạn phải qua trần đó. Thêm trần tổng tin chờ xuyên danh mục.

B2 Sửa tỉnh, phường, thuộc tính không phải duyệt lại

Cao

§7.4 §8.3

Vấn đề	Danh sách "phần đã được duyệt" chỉ gồm tiêu đề, mô tả, giá, danh mục, ảnh. Đối phường sau khi duyệt là đối ô định tuyến, tức đối người chịu trách nhiệm, mà không ai nhìn. Đối thuộc tính như "tình trạng: mới" là đối thứ người mua lọc theo.
Code hiện tại	Cũng thiếu. Hàm so sánh chỉ xét đúng năm trường đó. Lỗi chung của cả hai bản.
Đề xuất	Thêm thuộc tính, tỉnh, phường, bậc phủ sóng và nhóm đích vào §7.4. Đối ô định tuyến thì tin về hàng đợi của ô mới.

B3 Tự duyệt tin của mình vẫn được phép, và cơ chế quản chế biến mất

Cao

§2.1 §10.4

Vấn đề	§10.4 chỉ nói tự duyệt "không cộng uy tín", nghĩa là vẫn được duyệt. §2.1 lập luận cả hệ hai trực tồn tại để "luôn có bên thứ hai". Người phụ trách ô danh mục cũng tự duyệt được tin sản của mình trong ô đó.
Code hiện tại	Có van an toàn. Quản chế (quyết định 1.12): người bị quản chế thì tin phải do người khác duyệt, máy không duyệt hộ, không tự đăng. Đặc tả không nhắc tới quản chế một chữ.
Đề xuất	Đưa quản chế vào §11 như một trạng thái của uy tín, kèm bất biến "người bị quản chế không tự duyệt, không được máy duyệt". Cần nhắc cấm hẳn tự duyệt với tin bạc Sản chung.

B4 Tài khoản mới ở bậc trần cộng với định danh chỉ bằng email

Cao

§3.1 §3.5 §11.1 §11.2

Vấn đề	§11.2 tự nói "người dùng bỏ tài khoản đi tạo cái mới là thứ cần tránh nhất", nhưng thiết kế khiến một email mới (mã 10 phút) là cách rẻ nhất để thoát khoá 3 lần hoặc bậc 0 và có lại quyền tự đăng ngay.
Hệ quả	Biện pháp duy nhất là củng cố KYC, và §3.5 gắn nhãn "tạm thời" cho nó. Khi cờ tắt, hệ không còn gì chống tài khoản dùng một lần.
Đề xuất	Một trong hai: tài khoản mới chưa có quyền tự đăng trong N ngày hoặc N tin được người duyệt; hoặc KYC là điều kiện của quyền tự đăng chứ không phải cờ môi trường.

B5 Khoá 3 lần và tự hồi 30 ngày chưa nối với nhau

Trung bình

§11.4 §12.1

Vấn đề	§12.1 nói khoá quyền đăng "cần người gỡ tay". §11.4 nói bậc tự hồi +1 sau 30 ngày không vi phạm. Khoá có tự mở theo không? Lướt từ chối của máy (A1) có làm đồng hồ 30 ngày chạy lại không?
Đề xuất	Ghi rõ: khoá 3 lần tự hết theo cửa sổ 7 ngày hay giữ tới khi người gỡ; và định nghĩa "vi phạm mới" của §11.4 bao gồm những mức độ nào.

B6 Trần giá 50 triệu là trần chung cho mọi danh mục

Trung bình

§6.1 §9.3

Vấn đề	Với bất động sản và xe cộ thì mọi tin đều vượt 50 triệu, nên cờ "giá vượt trần" thành "luôn duyệt tay" cho cả danh mục, làm cờ riêng ở §6.1 thừa và dồn toàn bộ tin của hai danh mục lớn lên người duyệt.
Đề xuất	Trần theo danh mục. Ứng dụng đã có sẵn thang giá theo danh mục để dùng chung một nguồn.

B7 Tin miễn phí bị coi là giá dị thường

Trung bình

§9.3

Vấn đề	Phép kiểm "lệch quá 10 lần mức phổ biến" không miễn trừ giá 0, trong khi cho tặng là tính năng chính thức có nhãn và bộ lọc riêng.
Code hiện tại	Cũng dính. 0 nhân 10 luôn nhỏ hơn mức phổ biến, nên mọi tin cho tặng trong danh mục có đủ mẫu đều bị giữ lại chờ người duyệt.
Đề xuất	Miễn trừ giá 0 khỏi phép kiểm tương đối, hoặc coi 0 là một dải riêng. Ghi tường minh vào §9.3.

B8 Ẩn hội thoại của tài khoản đã xóa làm người kia mất bằng chứng

Trung bình

§14.1

Vấn đề	"Ẩn ngay" áp cho cả hội thoại, nhưng hội thoại có hai người. Người còn lại có thể cần nó để khiếu nại lừa đảo đúng trong 90 ngày đó.
Code hiện tại	Ẩn theo từng người tham gia. Xóa khỏi hộp thư của một bên không đụng bên kia.
Đề xuất	Ghi: chỉ ẩn phía người đã xóa; bên còn lại giữ quyền đọc tới khi xóa cứng.

B9 Cờ bỏ qua xác thực email và job xóa tài khoản chưa xác thực

Trung bình

§3.5 §14.1

Vấn đề	Nếu cờ bật mà không đánh dấu tài khoản là đã xác thực thì job 7 ngày xóa cứng mọi tài khoản demo.
Code hiện tại	Đã đúng. Cờ bật thì đặt thời điểm xác thực ngay lúc tạo, nên job không đụng tới.
Đề xuất	Thêm một câu vào §3.5: cờ này đánh dấu tài khoản là đã xác thực tại thời điểm tạo.

B10 Chủ tin rút ngắn được thời gian lưu bằng chứng vi phạm

Trung bình

§7.2 §14.1

Vấn đề	Tin bị từ chối giữ 90 ngày, nhưng "Bất kỳ → Đã xóa" rồi 30 ngày là xóa cứng kèm ảnh. Nhật ký "không kèm nội dung" không giải quyết được tranh chấp về hàng cấm.
Đề xuất	Tin bị từ chối mức vi phạm giữ nguyên đồng hồ 90 ngày dù chủ tin xóa mềm.

B11 Ai được bỏ ẩn một tin đã ẩn

Trung bình

§7.2 §10.2

- Vấn đề §10.2 cho nhóm ẩn tin sàn mang tên mình. §7.2 cho "người duyệt" bỏ ẩn mà không nói người duyệt nào. Nếu người phụ trách ô danh mục bỏ ẩn được thứ nhóm vừa ẩn thì quyền "từ chối cho mượn tên" của nhóm là rỗng.
- Đề xuất Lưu ai ẩn và vì sao; chỉ người đó hoặc quản trị hệ thống bỏ ẩn.

B12 Badge của nhóm riêng tư lộ ra sàn chung

Trung bình

§4.3 §8.3

- Vấn đề §8.3 cho thành viên nhóm riêng tư đăng tin sàn mang badge "đăng bởi nhóm X". §4.3 nói nhóm riêng tư trả 404 với người ngoài. Tên và sự tồn tại của nhóm vẫn lộ qua badge.
- Đề xuất Tin sàn của thành viên nhóm riêng tư không mang badge công khai, hoặc chỉ hiện badge với thành viên nhóm đó.

B13 Bảng chuyển trạng thái thiếu vài đường bình thường, gia hạn không qua cổng

Thấp

§7.2 §7.3 §8.1

- Vấn đề Thiếu: rút tin đang chờ về nháp; sửa phần đã duyệt của tin hết hạn; người ngoài vừa vào nhóm khi tin còn ở hàng đợi người ngoài. Gia hạn Hết hạn → Đang hiển thị không chạy lại cổng cụm cấm và chốt "danh mục còn dùng được", dù từ điển cấm có thể đã đổi.
- Đề xuất Thêm các dòng trên vào §7.2 (hoặc ghi rõ là từ chối có chủ ý), và ghi "gia hạn chạy lại chốt 1 và chốt 4".

B14 Thứ tự "hạ bậc trước, gạt cờ sau" không chặn tin tạo đồng thời

Thấp

§4.3 BT-03 §16.3

- Vấn đề Giữa hai bước vẫn có thể có một request tạo tin bậc Nhóm công khai. Một tiến trình không làm các request tuần tự.
- Đề xuất Khoá nhóm hoặc trạng thái "đang chuyển" trong lúc hạ bậc; chốt tạo tin từ chối khi nhóm đang ở trạng thái đó.

B15 Hạn mức người ngoài đếm theo từng nhóm

Thấp

§12.1 §12.2

- Vấn đề "Người ngoài: 2, cứng" đếm theo nhóm, nên một người gửi được 2 tin chờ vào mỗi nhóm trong hàng trăm nhóm.
- Đề xuất Thêm trần tổng tin chờ của người ngoài xuyên mọi nhóm.

C. Đặc tả đổi chiều so với code đang chạy mà không nêu lý do

C1	Nhấn tin trên tin đã bán hoặc hết hạn	Trung bình
§13.1		
Vấn đề	"Xem được là nhấn được", mà tin hết hạn và đã bán vẫn xem được. Người bán đồ đã bán sẽ tiếp tục nhận hội thoại mới.	
Code hiện tại	Khác đặc tả. Cố ý chỉ cho mở hội thoại mới trên tin đang hiển thị; hội thoại cũ vẫn đọc tiếp được.	
Đề xuất	Giữ luật của code. Nếu đổi thì phải gắn nhãn SỬA kèm lý do, không để dưới nhãn GIỮ.	

C2	Máy duyệt hộ cả người ở bậc 0	Trung bình
§9.2		
Vấn đề	§9.2 không đặt điều kiện uy tín cho quyền "duyet" của máy.	
Code hiện tại	Khác đặc tả. Có bậc tối thiểu để máy tự duyệt; dưới bậc đó máy chỉ giữ lại cho người thật.	
Đề xuất	Thêm điều kiện "người đăng từ bậc 1 trở lên và không bị quản chế" vào quyền duyệt của máy.	

Bảng tổng hợp

Mã	Vấn đề	Mức	Code hiện tại
A1	Lượt từ chối của máy không thuộc mức độ nào	Cao	—
A2	Ba câu khác nhau về nhóm đích	Cao	—
A3	Đường vào nhóm riêng tư, bốn tổ hợp công tắc	Trung bình	—
A4	Một quản trị hệ thống, không có đường khôi phục	Cao	—
A5	Báo cáo về người đi sai hàng đợi	Trung bình	Đã đúng
A6	"Sửa rồi đăng lại" không có đường đi	Cao	Đã đúng
B1	Không có trần tin đang hiển thị	Cao	Có trần
B2	Sửa tỉnh, phường, thuộc tính không duyệt lại	Cao	Cũng thiếu
B3	Tự duyệt tin của mình, mất cơ chế quản chế	Cao	Có quản chế
B4	Tài khoản mới bậc trần, định danh chỉ bằng email	Cao	—
B5	Khoá 3 lần và tự hồi 30 ngày chưa nổi	Trung bình	—
B6	Trần giá 50 triệu chung cho mọi danh mục	Trung bình	—

B7	Tin miễn phí bị coi là giá dị thường	Trung bình	Cũng dính
B8	Ẩn hội thoại của tài khoản đã xoá	Trung bình	Đã đúng
B9	Cờ bỏ qua xác thực vs job xoá tài khoản	Trung bình	Đã đúng
B10	Chủ tin rút ngắn lưu bằng chứng	Trung bình	—
B11	Ai được bỏ ẩn	Trung bình	—
B12	Badge nhóm riêng tư lộ ra sàn	Trung bình	—
B13	Thiếu đường chuyển trạng thái, gia hạn không qua cổng	Thấp	—
B14	Race khi chuyển nhóm sang riêng tư	Thấp	—
B15	Hạn mức người ngoài theo từng nhóm	Thấp	—
C1	Nhắn tin trên tin đã bán hoặc hết hạn	Trung bình	Khác đặc tả
C2	Máy duyệt hộ người bậc 0	Trung bình	Khác đặc tả

Ba thay đổi mà bản đích tự đánh dấu "đáng tranh luận" (§8.2 bắt buộc nêu bậc phủ sóng, §11.4 tự hồi sau 30 ngày, §14.1 giữ 90 ngày) không tính là lỗi. Riêng §11.4 cần đọc cùng B5 trước khi quyết.

Tài liệu rà soát, không phải đặc tả. Không có file nào trong hai bản PDF nguồn hay trong mã nguồn bị sửa trong lượt rà soát này.